

How to Detect SQL Injection, XSS & File Inclusion with Wazuh SIEM

Testing web-based attacks means we want to see if our WAZUH SIEM can detect cyber-attacks on our web server, like SQL injection, cross-site scripting, file inclusion, or command injection. This process is called intrusion detection.

There are three phases to this entire process.

Phase one: Setting up the test environment.

In the phase we need a vulnerable web application on which we will perform or test the attacks, and for this, we are using DVWA (Damn Vulnerable Web Application). We will perform this on the Linux machine or WAZUH Linux agent.

1- Prerequisites installation

A- use this command: `sudo apt update -y` and hit enter to first setup our environment server.

B- Set up our environment server (Wazuh Linux agent) for apache2, php, php-mysqli, php-gd, mariadb-server using this command: `sudo apt install apache2 php php-mysqli php-gd mariadb-server -y`. It will download all these servers or dependencies directly.

NB:

Apache2: It is our web server that hosts and serves web pages (DVWA) to users.

PHP: It is our server-side scripting language used to build dynamic websites and apps.

php-mysqli: It is our PHP extension that enables scripts to connect and interact with MariaDB/MySQL databases.

php-gd: It is our PHP library used for creating and manipulating images (like resizing or generating captchas).

MariaDB-server: It is our database management system used to store and organize application data.

2- Download and set up DVWA

A- Download DVWA (<https://github.com/tim87tchoua/DVWA.git>). Go into this directory `/var/www/html` (`cd /var/www/html`) and download the DVWA via git using the command: `sudo git clone https://github.com/tim87tchoua/DVWA.git`

B- Assign full ownership of the DVWA files to our web server, Apache using this command: `sudo chown -R www-data:www-data DVWA/`

NB: www-data is the standard default user and group used by the Apache web server (as well as Nginx) on Ubuntu and Debian-based Linux distributions. When Apache runs background processes to serve your website, it runs them under this restricted system user account for security reasons, ensuring that if a web application is compromised, the attacker doesn't get full root access to your entire server.

C- Set up your database by using this command: `sudo mysql -u root`. And add this command prompt:

```
CREATE DATABASE dvwa;  
CREATE USER 'dvwa'@'localhost' IDENTIFIED BY 'p@ssw0rd';  
GRANT ALL PRIVILEGES ON dvwa.* TO 'dvwa'@'localhost';  
FLUSH PRIVILEGES;  
exit
```

that will create the DVWA database and assign a user to it. Our database has been created, and the password has been assigned. It has created its user too.

D- Configure DVWA: means just duplicating its template (config.inc.php.dist)

Do: navigate into DVWA/config (`cd DVWA/config`) and copy the configuration file (config.inc.php.dist) into this file config.inc.php using the command: `sudo cp config.inc.php.dist config.inc.php`

NB: make sure that our config.inc.php file shows the password inside it (`sudo nano config.inc.php`).

```
$_DVWA = array();  
$_DVWA['db_server'] = getenv('DB_SERVER') ? '127.0.0.1';  
$_DVWA['db_database'] = getenv('DB_DATABASE') ? 'dvwa';  
$_DVWA['db_user'] = getenv('DB_USER') ? 'dvwa';  
$_DVWA['db_password'] = getenv('DB_PASSWORD') ? 'p@ssw0rd';  
$_DVWA['db_port'] = getenv('DB_PORT') ? '3306';
```

here you can see that the password is being shown. It means that it has been configured.

E- Restart your Apache server using the command: `sudo systemctl restart apache2` and go to the browser and access DVWA where it is your Linux machine (<http://192.168.40.222/DVWA/setup.php>).



Scroll down and click on Create/Reset Database to reach this page:



The username here is `admin` and the password is `password` for the first login, you can change it after.

Scroll down and here we will have the option for **DVWA Security**. Change this from impossible to **low** and click on submit.



Reach this step, we have set up our vulnerable web application.

Phase two: Enable the detection rules on our WAZUH server.

Enabling detection rule in wazuh server will basically help to detect the provided commands.

Do: on your wazuh manager, go on `/var/ossec/etc/rules/local_rules.xml` (**`sudo nano /var/ossec/etc/rules/local_rule.xml`**), go to the end of this file and add this code block.

```
<group name="web,attacks,">

<!-- XSS Detection -->
<rule id="200901" level="12">
  <if_sid>31101</if_sid>
<match>&lt;script&gt;|script.alert|script.confirm|script.prompt|onmouseover=|onload=|&lt;img.src|java</match>
  <description>Possible Cross-Site Scripting (XSS) attempt detected.</description>
  <group>web_attack,xss,</group>
</rule>

<!-- Command Injection Detection -->
<rule id="200902" level="12">
  <if_sid>31101</if_sid>
  <match>;ls|;cat|;id|;whoami|;pwd|&amp;&amp;|wget|curl|/bin/sh|/bin/bash</match>
  <description>Possible Command Injection attempt detected.</description>
  <group>web_attack,command_injection,</group>
</rule>

<!-- File Inclusion Detection -->
<rule id="200903" level="12">
  <if_sid>31101</if_sid>
  <match>etc/passwd|/proc/self|/var/log|php://input|php://filter|data://|expect://|http://|https://</match>
  <description>Possible File Inclusion attempt detected.</description>
  <group>web_attack,file_inclusion,</group>
</rule>
</group>
```

Save and restart wazuh manager

Configure your wazuh agent (Linux group) to send your Apache logs to the WAZUH server.

Do: Go to Agent Management, Groups, as we are using the Linux group, so click on it and add this code block:

```
<!-- Enable Apache Logs -->
<localfile>
  <log_format>apache</log_format>
  <location>/var/log/apache2/access.log</location>
</localfile>
<localfile>
  <log_format>apache</log_format>
  <location>/var/log/apache2/error.log</location>
</localfile>
```

Save and restart your WAZUH server.

Phase three: perform the attack tests.

- 1- **First test: Performed SQL injection** (Typing special commands into a website form to trick the system into giving up, changing, or deleting private database records.)

Do: Click on **SQL Injection** and paste this script:

```
%27 or 1=1 --
```

and click on submit.

- 2- **Second test: Perform Cross-Site Scripting (XSS)** (Hiding harmful code on a trusted webpage so it attacks your customers or visitors when they open the site)

Do: click on **XSS (Reflected)** and paste this script:

```
<script>alert('Wazuh Detected This!')</script>
```

and click submit.

- 3- **Third test: Perform command injection** (Tricking a website into opening private system files or folders that should remain locked away.)

Do: Click on **Command Injection** and past this script:

```
127.0.0.1; cat /etc/passwd
```

and click on submit.

After that, go to the WAZUH dashboard and see if these attacks were detected or not. So, you can see that your intrusion detection system has detected web attacks and it is working perfectly.

